

Security+ 5.6 • User Training

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 5.6 — User Training (4:31)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: User training targets employees, management, and third parties/suppliers. Delivery methods include in-person, online, email, and CTF. Frequency: at hire, periodically, and after incidents. Training should be customized by role (executives: whaling; finance: BEC).

High-Yield Core Concepts Tested on Exam

- Train by role: executives receive whaling training; finance receives BEC training
- Frequency: at hire + periodic + after incident
- Delivery: in-person, online, email, CTF
- Target audiences: employees, management, third parties

Exam Tips & Classic Scenarios

- 'training customized based on job role' = role-based awareness training
- If an executive receives specific whaling training, it's role-based customization

Typical Exam Scenario: An executive receives training specifically about whaling attacks. This is an example of role-based customization.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 5.6 — User Training)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A scammer calls pretending to be IT support and creates urgency for you to give your password. The social engineering principle exploited is:

- A)** Scarcity
- B)** Authority + urgency
- C)** Social proof
- D)** Reciprocity

2. An employee receives a call from someone pretending to be technical support asking for a password for a 'system update'. What technique is this?

- A) Vishing**
- B) Pretexting**
- C) Baiting**
- D) Tailgating**

3. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'Train BY ROLE: executives receive whaling; finance receives BEC.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Replace preventive technical controls with informal terms of adherence**
- C) Implement the corresponding solution: Train BY ROLE: executives receive whaling; finance receives BEC...**
- D) Allow shared access among administrators using generic credentials**

4. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'Frequency: onboarding + periodic + after incident.' What is the best recommendation or applicable control classification?

- A) Temporarily disable audit logs to accelerate system throughput**
- B) Implement the corresponding solution: Frequency: onboarding + periodic + after incident...**
- C) Replace preventive technical controls with informal terms of adherence**
- D) Allow shared access among administrators using generic credentials**

5. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'training customized based on job role' = role-based awareness training. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'training customized based on job role' = role-based awareness training...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'executive receives specific whaling training' = role-based customization'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'executive receives specific whaling training' = role-based customization...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ (SY0-701, Section 5.6) exam, an analyst evaluates the following technical requirement: 'Train BY ROLE: executives receive whaling; finance receives BEC'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Train BY ROLE: executives receive whaling; finance receives BEC...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'Frequency: onboarding + periodic + after incident'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Frequency: onboarding + periodic + after incident...

9. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'training customized based on job role' = role-based awareness training. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to speed up system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'training customized based on job role' = role-based awareness training...

10. Corporate scenario (User Training): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 5.6), an analyst evaluates the following technical requirement: 'executive receives specific whaling training' = role-based customization. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'executive receives specific whaling training' = role-based customization...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) B — Authority + urgency.

✓ **Why it's correct:** The correct alternative is 'Authority + urgency'. Social engineering exploits cognitive biases and psychological principles to manipulate victims. In the scenario, the scammer impersonates IT support, which invokes the principle of authority (the victim tends to obey authority figures). Additionally, he creates a sense of urgency to pressure the victim to act quickly, without thinking critically. The combination of authority and urgency is a classic social engineering tactic, recognized by CompTIA. Therefore, the option 'Authority + urgency' accurately describes the principles exploited.

✗ **Why the others are wrong:**

- *Scarcity*: Scarcity is a persuasion principle that exploits the perception that resources are limited, creating a feeling that the opportunity may be lost if not acted upon immediately. In the scenario, there is no mention of scarce resources or limited offers. The scammer is not offering something in limited quantity, but rather impersonating authority and creating urgency. Therefore, scarcity is not the applicable principle.
- *Social proof*: Social proof is the tendency for people to follow the behavior of others, assuming that actions taken by many are correct. In the described attack, there is no mention of other people doing the same or endorsing the action. The scammer does not use the idea that 'everyone is doing it' to convince the victim. Therefore, social proof is not the principle exploited.
- *Reciprocity*: Reciprocity is the principle that people feel obliged to return a favor or concession. In the scenario, the scammer does not offer anything first and then ask for the password; he simply impersonates support and creates urgency. There is no exchange of favors. Therefore, reciprocity does not apply.

2) A — Vishing.

✓ **Why it's correct:** The correct answer is 'Vishing'. Vishing is a combination of 'voice' and 'phishing', i.e., social engineering conducted via telephone calls (VoIP or traditional telephone network). In the described scenario, the attacker impersonates technical support to obtain the victim's password, exactly characterizing a vishing attack. CompTIA Security+ classifies vishing as a voice-based social engineering attack, where real-time interaction increases psychological pressure and perceived credibility. The goal is to induce the victim to reveal credentials or perform harmful actions.

✗ **Why the others are wrong:**

- *Pretexting*: Pretexting is the creation of a false scenario or pretext to obtain information. Although the attacker in the statement uses a pretext (fake technical support), the primary vector is the telephone. Pretexting is a common element in many social engineering attacks, including vishing, phishing, and smishing. The alternative is incorrect because it does not specify the telephone channel, which is the defining characteristic of vishing. Technically, pretexting is the technique of building the story, while vishing is the delivery method via voice.
- *Baiting*: Baiting involves leaving a physical device (such as an infected USB drive) or a digital lure for the victim to use, exploiting curiosity. There is no relation to telephone calls or direct password requests by voice. The alternative is incorrect because it describes an attack that depends on physical action or interaction with removable media, not real-time verbal interaction.
- *Tailgating*: Tailgating is a physical unauthorized access technique where the attacker follows an authorized employee through a secure door without authenticating. It does not involve telephone, verbal social engineering, or obtaining a password. The alternative is incorrect because it belongs

to the category of physical attacks, while the scenario describes a remote voice social engineering attack.

3) C — Implement the corresponding solution: Train BY ROLE: executives receive whaling; finance receives BEC....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): Train BY ROLE: executives receive whaling; finance receives BEC. Role-based security awareness training tailors content to the specific threats and responsibilities of different job functions, such as whaling attacks targeting executives and Business Email Compromise (BEC) targeting finance departments.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

4) B — Implement the corresponding solution: Frequency: onboarding + periodic + after incident....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): Frequency: onboarding + periodic + after incident. This ensures that users receive security awareness training when they join the organization, at regular intervals, and after any security incident to reinforce lessons learned and prevent recurrence.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

5) B — Implement the corresponding solution: 'training customized based on job role' = role-based awareness training....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): 'training customized based on job role' = role-based awareness training. Role-based awareness training tailors security education to the specific responsibilities and risks associated with an employee's job function, making it more relevant and effective.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: 'executive receives specific whaling training' = role-based customization....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): 'executive receives specific whaling training' = role-based customization. Role-based training tailors security awareness to specific job roles, such as executives who are prime targets for whaling attacks.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Train BY ROLE: executives receive whaling; finance receives BEC....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): Train BY ROLE: executives receive whaling; finance receives BEC.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) D — Implement the corresponding solution: Frequency: onboarding + periodic + after incident....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): Frequency: onboarding + periodic + after incident. Effective security awareness training must be conducted at key intervals: when employees are hired (onboarding), at regular intervals (periodic), and after a security incident to reinforce lessons learned.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks

compliance standards (PCI DSS, ISO 27001).

- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

9) D — Implement the corresponding solution: 'training customized based on job role' = role-based awareness training....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): 'training customized based on job role' = role-based awareness training. Role-based awareness training tailors security education to the specific responsibilities and risks associated with an employee's job function. The appropriate control is to implement the corresponding solution, which ensures that employees receive relevant training to mitigate role-specific threats.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to speed up system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: 'executive receives specific whaling training' = role-based customization....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 5.6 (User Training): 'executive receives specific whaling training' = role-based customization. Role-based training tailors security awareness to the specific risks and responsibilities of different roles. Executives are prime targets for whaling (CEO fraud), so they need specialized training.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

